

SOC 2 & HIPAA Security Readiness Assessment

Azure Healthcare Security Architecture

Prepared by	Harrison Knapp
Assessment date	September 2026
Assessment type	Technical security readiness / gap assessment
Environment	Microsoft Azure - Enterprise Security Landing Zone

Assessment limitation. This document is a portfolio-based technical readiness assessment. It does not constitute a SOC 2 examination or attestation, HIPAA certification, legal opinion, or independent determination of compliance.

1. Executive Summary

This assessment evaluates a healthcare-focused Azure landing zone against selected security objectives from the AICPA Trust Services Criteria and the HHS/OCR HIPAA Security Rule Audit Protocol. The environment demonstrates a strong technical security foundation across identity, network isolation, encryption, governance, audit logging, change monitoring, and data recovery controls.

IMPLEMENTED	Strongest areas Private connectivity, network segmentation, customer-managed encryption, Azure RBAC, policy enforcement, centralized audit logging, and KQL validation.
PARTIAL / GAP	Primary technical gaps Continuous workload vulnerability scanning, formal backup/PITR testing, and production-grade privileged access lifecycle controls.
OUT OF LAB SCOPE	Organizational controls Formal workforce training, physical safeguards, BAAs, legal/privacy processes, management approvals, and enterprise incident/change procedures.

Executive conclusion

The environment is well positioned as a cloud security engineering portfolio project because the controls were not only configured, but several were deliberately tested and validated. The strongest evidence is the end-to-end audit trail: an Azure administrative change was generated, recorded in the Azure Activity Log, forwarded to Log Analytics, and detected with KQL. Remaining gaps are documented rather than obscured, which improves the credibility of the readiness assessment.

2. Scope & System Boundary

In scope	Azure management-group governance; subscription controls; hub-spoke networking; Web/App/Data segmentation; NSGs; Private Link/Private DNS; Key Vault; customer-managed keys; Storage; Azure Policy; Activity Logs; Log Analytics; KQL monitoring; Foundational CSPM.
Data assumption	Synthetic healthcare workload data representing an environment that could process or store ePHI. No real patient data is required for this portfolio assessment.
Out of scope	Physical facilities, workforce training records, BAAs/vendor contracts, legal/privacy determinations, enterprise policy approval, HR sanctions, and independent audit procedures.

3. Assessment Methodology

Controls were assessed using a design-and-evidence approach: identify the security objective, review the Azure implementation, capture supporting evidence, perform a technical validation where practical, record the result, and document residual risk or production improvements. Ratings used in this report are readiness ratings, not audit opinions.

Rating	Meaning
--------	---------

Implemented	Control is configured and supported by project evidence.
Implemented / Improvement	Control is present, but a production-strength enhancement is recommended.
Partial / Gap	Some supporting controls exist, but the objective is not fully demonstrated.
Out of Lab Scope	Requires organizational, legal, physical, or process evidence beyond the Azure lab.

4. SOC 2 Readiness Assessment

The following controls are mapped to relevant AICPA Trust Services Criteria areas. This is a readiness crosswalk and not a substitute for an independent SOC 2 examination.

SOC2-CC6-01 - Logical Access & Least Privilege		IMPLEMENTED / IMPROVEMENT
Implementation		Azure RBAC separates development and security responsibilities. A user-assigned managed identity is granted a narrow Key Vault cryptographic role.
Observation / Gap		Standing Owner privileges remain in the lab.
Recommendation		Use PIM/JIT, Conditional Access, phishing-resistant MFA, and periodic access reviews in production.
Evidence		Management-group RBAC and subscription IAM evidence.

SOC2-CC6-02 - Network & Private Data Access		IMPLEMENTED
Implementation		Hub-spoke architecture, Web/App/Data subnet segmentation, NSG allow/deny rules, Private Endpoints, and Private DNS restrict workload access paths.
Observation / Gap		Centralized egress inspection is not deployed in the cost-controlled lab.
Recommendation		Add Azure Firewall/NVA and UDR-based egress inspection where the production threat model requires it.
Evidence		NSG, peering, private endpoint, and DNS evidence.

SOC2-CC6-03 - Encryption & Key Management		IMPLEMENTED / IMPROVEMENT
Implementation		Storage uses a customer-managed RSA key in Key Vault through a managed identity. Key Vault purge protection and soft delete are enabled; TLS 1.2 and secure transfer are enforced.
Observation / Gap		Storage Shared Key remains enabled.
Recommendation		Prefer Entra ID/RBAC and disable Shared Key where application compatibility permits.
Evidence		Storage encryption and Key Vault evidence.

SOC2-CC7-01 - Centralized Security Logging		IMPLEMENTED & VALIDATED
Implementation		Subscription Activity Logs and resource diagnostics are centralized in Log Analytics.
Observation / Gap		Production retention and review cadence are not formally defined.
Recommendation		Define retention, alert ownership, severity, and response SLAs.
Evidence		22-centralized-activity-log-validation.png

SOC2-CC7-02 - Security Monitoring & Incident Detection		IMPLEMENTED / IMPROVEMENT
Implementation		KQL detects changes to Azure Policy, RBAC, NSGs, and Key Vault. A real policy assignment deletion was detected with initiating identity and source IP.
Observation / Gap		The lab does not demonstrate a full production detection catalog or formal incident program.
Recommendation		Formalize playbooks, escalation, communications, evidence handling, and tabletop testing.
Evidence		23-security-control-change-detection.png

SOC2-CC7-03 - Vulnerability Management		PARTIAL / GAP
Implementation		Foundational CSPM is enabled and preventive Azure Policy controls are in place.
Observation / Gap		Continuous workload vulnerability scanning and remediation SLA are not demonstrated.
Recommendation		Implement continuous scanning, risk-based prioritization, remediation SLAs, compensating controls, and rescanning.
Evidence		21-defender-foundational-cspm.png

SOC2-CC8-01 - Change Management & Auditability		IMPLEMENTED & VALIDATED
Implementation		Azure Policy provides preventive governance; administrative changes are attributable by identity, time, status, and resource. Logging was validated with KQL.
Observation / Gap		Formal ticket/approval workflow is outside the lab.
Recommendation		Integrate production change requests, approvals, implementation evidence, and post-change validation.
Evidence		Policy evidence plus 22/23 KQL evidence.

5. HIPAA Security Rule Readiness

The HIPAA portion focuses on technical safeguards and selected administrative safeguards relevant to the Azure landing zone. The assessment intentionally separates technical evidence from organizational requirements that cannot be proven by cloud configuration alone.

HIPAA-RA-01 - Risk Analysis & Risk Management		IMPLEMENTED / IMPROVEMENT
Reference		45 CFR 164.308(a)(1)(ii)(A)-(B)
Implementation		The project identifies technical risks, validates controls, records gaps, and documents remediation priorities.
Observation / Gap		This is not an enterprise-wide HIPAA risk analysis covering every ePHI system, threat, process, vendor, and facility.

HIPAA-AC-01 - Access Control		IMPLEMENTED
Reference		45 CFR 164.312(a)(1)
Implementation		Azure RBAC, tiered network segmentation, private endpoints, and scoped managed identities restrict access to cloud resources.
Observation / Gap		Production should add formal access recertification and JIT privileged access.

HIPAA-AU-01 - Audit Controls		IMPLEMENTED & VALIDATED
Reference		45 CFR 164.312(b)
Implementation		Azure administrative activity is centralized in Log Analytics and was validated with KQL after a policy change.
Observation / Gap		Production should establish formal log retention and review requirements.

HIPAA-IN-01 - Integrity		IMPLEMENTED / IMPROVEMENT
Reference		45 CFR 164.312(c)(1)
Implementation		CMK encryption, versioning, soft delete, change feed, and governance policies support protection against unauthorized alteration or destruction.
Observation / Gap		Application-level integrity controls are outside the current lab.

HIPAA-TS-01 - Transmission Security		IMPLEMENTED
Reference		45 CFR 164.312(e)(1)
Implementation		TLS 1.2, secure transfer, Private Link, Private DNS, and subnet segmentation protect network paths.
Observation / Gap		Production egress inspection should be added when risk and architecture justify it.

HIPAA-IR-01 - Security Incident Procedures		IMPLEMENTED / IMPROVEMENT
Reference		45 CFR 164.308(a)(6)
Implementation		KQL detection and a documented investigation sequence demonstrate technical incident detection and triage.
Observation / Gap		Formal organizational response policy, communications, escalation, and exercises remain outside the lab.

HIPAA-CP-01 - Contingency Planning		PARTIAL / GAP
Reference		45 CFR 164.308(a)(7)
Implementation		Blob/container soft delete, versioning, and change feed provide object-level recovery capability.
Observation / Gap		No formal RPO/RTO, Azure Backup/PITR implementation, or tested recovery exercise is demonstrated.

HIPAA-DOC-01 - Policies & Documentation		PARTIAL / GAP
Reference		45 CFR 164.316
Implementation		The project maintains technical evidence and this readiness report.
Observation / Gap		Formal approved policies, procedures, retention, workforce records, and enterprise documentation lifecycle are outside the lab.

6. Priority Risk & Gap Register

ID	Priority	Finding	Recommended Treatment
R-01	High	Continuous workload vulnerability scanning is not demonstrated.	Deploy continuous assessment; prioritize by exploitability, exposure and data sensitivity; define remediation SLAs and rescan.
R-02	High	Standing privileged access increases blast radius.	Use PIM/JIT, Conditional Access, phishing-resistant MFA and access reviews.
R-03	High	Formal backup/PITR and tested recovery objectives are not demonstrated.	Define RPO/RTO, implement appropriate backup, and perform documented restore tests.
R-04	Medium	Storage Shared Key remains enabled.	Disable Shared Key where compatible and require Entra ID/RBAC.
R-05	Medium	No centralized firewall/egress inspection in the cost-controlled lab.	Add Azure Firewall/NVA and egress policy in production where risk warrants.
R-06	High	Formal incident/change procedures and approvals are outside lab scope.	Create approved procedures, escalation matrices, change tickets, exercises, and evidence retention.

Risk treatment philosophy

The lab intentionally avoids deploying expensive services solely to make every assessment row green. Production controls such as centralized firewalling, advanced vulnerability management, privileged identity lifecycle management, and backup services should be selected based on risk, regulatory scope, workload criticality, and recovery objectives.

7. Evidence Index

ID	Artifact	Control Evidence
E-01	Management-group / RBAC evidence	Role separation and inheritance
E-02	NSG / peering / subnet evidence	Web-App-Data segmentation
E-03	Private Endpoint / Private DNS evidence	Private service connectivity
E-04	Storage CMK / Key Vault evidence	Encryption and key management
E-05	18-landing-zone-policy-assignments.png	Management-group governance
E-06	19-allowed-locations-policy-enforcement.png	Regional Deny policy
E-07	Policy denial test	Preventive governance validation
E-08	20-storage-data-protection-controls.png	Recovery and change tracking
E-09	21-defender-foundational-cspm.png	Foundational CSPM coverage
E-10	22-centralized-activity-log-validation.png	End-to-end audit ingestion
E-11	23-security-control-change-detection.png	KQL security-control detection

8. Framework Sources & Assessment Limitations

AICPA Trust Services Criteria. 2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy, including revised points of focus (2022).

Source: <https://www.aicpa-cima.com/resources/download/2017-trust-services-criteria-with-revised-points-of-focus-2022>

U.S. Department of Health and Human Services, Office for Civil Rights. HIPAA Audit Protocol and Security Rule guidance.

Source: <https://www.hhs.gov/hipaa/for-professionals/compliance-enforcement/audit/protocol/index.html>

Source: <https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html>

Important limitations

This report evaluates a technical Azure portfolio environment. It does not test all AICPA Trust Services Criteria, all HIPAA Privacy/Breach Notification requirements, or all administrative and physical safeguards. It does not include independent sampling, management representations, legal review, workforce interviews, vendor/BAA review, physical inspection, or CPA attestation procedures.

Portfolio conclusion

The Enterprise Security Landing Zone demonstrates practical cloud security engineering: governance controls were designed and tested; policy failures and scope drift were identified and remediated; sensitive services were moved behind private connectivity; customer-managed encryption was implemented; centralized audit logging was validated; and a KQL detection was created for critical security-control changes. The documented gaps provide a realistic roadmap for production hardening rather than an unsupported claim of compliance.

Prepared for portfolio and interview demonstration purposes.